ZAP by Checkmarx Scanning Report

Generated with ZAP on Wed 15 Apr 2026, at 18:20:59

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- About This Report
  - Report Parameters
- Summaries
  - Alert Counts by Risk and Confidence
  - Alert Counts by Site and Risk
  - Alert Counts by Alert Type
  - Insights
- Alerts
  - Risk=High, Confidence=Medium (2)
  - Risk=Medium, Confidence=High (1)
  - Risk=Medium, Confidence=Medium (2)

- Risk=Medium, Confidence=Low (1)
- Risk=Low, Confidence=Medium (2)
- Risk=Informational, Confidence=High (1)
- Risk=Informational, Confidence=Medium (5)
- Risk=Informational, Confidence=Low (1)

- Appendix
  - Alert Types

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- `http://127.0.0.1:8080`

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: `High`, `Medium`, `Low`, `Informational`

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	2 (13.3%)	0 (0.0%)	2 (13.3%)
	Medium	0 (0.0%)	1 (6.7%)	2 (13.3%)	1 (6.7%)	4 (26.7%)
	Low	0 (0.0%)	0 (0.0%)	2 (13.3%)	0 (0.0%)	2 (13.3%)
	Informational	0 (0.0%)	1 (6.7%)	5 (33.3%)	1 (6.7%)	7 (46.7%)
	Total	0 (0.0%)	2 (13.3%)	11 (73.3%)	2 (13.3%)	15 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	http://127.0.0.1:80	2	4	2	7
	80	(2)	(6)	(8)	(15)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Advanced SQL Injection - AND boolean-based blind - WHERE or HAVING clause	High	1 (6.7%)
SQL Injection	High	1 (6.7%)
Total		15

Alert type	Risk	Count
Absence of Anti-CSRF Tokens	Medium	5 (33.3%)
Content Security Policy (CSP) Header Not Set	Medium	5 (33.3%)
Missing Anti-clickjacking Header	Medium	5 (33.3%)
Spring Actuator Information Leak	Medium	1 (6.7%)
Cookie without SameSite Attribute	Low	1 (6.7%)
X-Content-Type-Options Header Missing	Low	5 (33.3%)
Authentication Request Identified	Informational	1 (6.7%)
Session Management Response Identified	Informational	1 (6.7%)
Tech Detected - Bootstrap	Informational	1 (6.7%)
Tech Detected - Font Awesome	Informational	1 (6.7%)
Tech Detected - Java	Informational	1 (6.7%)
User Agent Fuzzer	Informational	5 (33.3%)
Total		15

Alert type	Risk	Count
User Controllable HTML Element Attribute (Potential XSS)	Informational	4 (26.7%)
Total		15

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	3
Low	Warning		ZAP warnings logged - see the zap.log file for details	26
Info	Informational	http://127.0.0.1:8080	Percentage of responses with status code 2xx	77 %
Info	Informational	http://127.0.0.1:8080	Percentage of responses with status code 3xx	21 %
Info	Informational	http://127.0.0.1:8080	Percentage of responses with status code 4xx	1 %
Info	Informational	http://127.0.0.1:8080	Percentage of endpoints with content type application/vnd.spring-boot.actuator.v3+json	5 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://127.0.0.1:8080	Percentage of endpoints with content type image/x-icon	5 %
Info	Informational	http://127.0.0.1:8080	Percentage of endpoints with content type text/css	22 %
Info	Informational	http://127.0.0.1:8080	Percentage of endpoints with content type text/html	55 %
Info	Informational	http://127.0.0.1:8080	Percentage of endpoints with method GET	88 %
Info	Informational	http://127.0.0.1:8080	Percentage of endpoints with method POST	11 %
Info	Informational	http://127.0.0.1:8080	Count of total endpoints	18
Info	Informational	http://127.0.0.1:8080	Percentage of slow responses	1 %
Info	Informational	http://clients2.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	http://clients2.google.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	http://clients2.goog	Percentage of endpoints with method GET	100 %

Level	Reason	Site	Description	Statistic
		le.com		
Info	Informati onal	http://clie nts2.goog le.com	Count of total endpoints	1

Alerts

Risk=High, Confidence=Medium (2)

http://127.0.0.1:8080 (2)

Advanced SQL Injection - AND boolean-based blind - WHERE or HAVING clause (1)

▶ POST http://127.0.0.1:8080/WebGoat/register.mvc

SQL Injection (1)

▶ POST http://127.0.0.1:8080/WebGoat/register.mvc

Risk=Medium, Confidence=High (1)

http://127.0.0.1:8080 (1)

Content Security Policy (CSP) Header Not Set (1)

▶ GET http://127.0.0.1:8080/sitemap.xml

Risk=Medium, Confidence=Medium (2)

http://127.0.0.1:8080 (2)

Missing Anti-clickjacking Header (1)

▶ GET http://127.0.0.1:8080/WebGoat/

Spring Actuator Information Leak (1)

▶ GET http://127.0.0.1:8080/WebGoat/actuator/health

Risk=Medium, Confidence=Low (1)

http://127.0.0.1:8080 (1)

Absence of Anti-CSRF Tokens (1)

▶ GET http://127.0.0.1:8080/WebGoat/

Risk=Low, Confidence=Medium (2)

http://127.0.0.1:8080 (2)

Cookie without SameSite Attribute (1)

▶ GET http://127.0.0.1:8080/WebGoat/

X-Content-Type-Options Header Missing (1)

▶ GET http://127.0.0.1:8080/WebGoat/

Risk=Informational, Confidence=High (1)

http://127.0.0.1:8080 (1)

Authentication Request Identified (1)

▶ POST http://127.0.0.1:8080/WebGoat/login

Risk=Informational, Confidence=Medium (5)

http://127.0.0.1:8080 (5)

Session Management Response Identified (1)

▶ GET http://127.0.0.1:8080/WebGoat/

Tech Detected - Bootstrap (1)

▶ GET http://127.0.0.1:8080/WebGoat/login

Tech Detected - Font Awesome (1)

▶ GET http://127.0.0.1:8080/WebGoat/login

Tech Detected - Java (1)

▶ GET http://127.0.0.1:8080/WebGoat/

User Agent Fuzzer (1)

▶ POST http://127.0.0.1:8080/WebGoat/login

Risk=Informational, Confidence=Low (1)

http://127.0.0.1:8080 (1)

User Controllable HTML Element Attribute (Potential XSS) (1)

▶ POST http://127.0.0.1:8080/WebGoat/register.mvc

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Advanced SQL Injection - AND boolean-based blind - WHERE or HAVING clause

Source	raised by an active scanner (Advanced SQL Injection)
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

SQL Injection

Source	raised by an active scanner (SQL Injection)
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Absence of Anti-CSRF Tokens

Source	raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID	352

WASC ID	9
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html ▪ https://cwe.mitre.org/data/definitions/352.html

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021

WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Spring Actuator Information Leak

Source	raised by an active scanner (Spring Actuator Information Leak)
CWE ID	215
WASC ID	13
Reference	▪ https://docs.spring.io/spring-boot/api/rest/actuator/index.html#overview

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15

Reference

- https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
- https://owasp.org/www-community/Security_Headers

Authentication Request Identified

Source raised by a passive scanner (Authentication Request Identified)

Reference

- https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

Session Management Response Identified

Source raised by a passive scanner (Session Management Response Identified)

Reference

- https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

Tech Detected - Bootstrap

Source raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)

WASC ID 13

Reference

- https://getbootstrap.com

Tech Detected - Font Awesome

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://fontawesome.com/

Tech Detected - Java

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://java.com

User Agent Fuzzer

Source	raised by an active scanner (User Agent Fuzzer)
Reference	▪ https://owasp.org/wstg

User Controllable HTML Element Attribute (Potential XSS)

Source	raised by a passive scanner (User Controllable HTML Element Attribute (Potential XSS))
CWE ID	20
WASC ID	20
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html